Where Does 99 % Accuracy on Phishing URL Detection Come From?

A leakage audit of PhiUSIIL, an honest host-name baseline, and exact client-side SHAP explanation

Johan Rodríguez
`github.com/Yoyagm/phishing-url-detector`

14 August 2026

Abstract

Published phishing-URL classifiers routinely report 99–100 % accuracy on public benchmarks. This report shows that on PhiUSIIL (UCI id 967, 235 795 URLs) the figure is an artifact of the data rather than a property of any model, and measures what remains once the artifacts are removed. Two independent label leaks are identified and quantified. The first is a single feature, `URLSimilarityIndex`, which alone yields 0.9967 accuracy. The second is structural: every legitimate URL in the dataset was normalised to `https://www.<domain>` at collection time while phishing URLs were captured raw, so the rule "has a path" is 0.6935 accurate and never fires on a legitimate row. The second leak survives the obvious remedy — discarding all precomputed columns and training on the raw URL string still yields 0.9951 accuracy. Restricting the model to canonicalised host names, splitting by registrable domain, and evaluating against phishing submitted two years after the training data gives ROC-AUC 0.9372 and 70.5 % recall at a 1 % false-positive rate. On a live feed captured the same day, 58.5 % of hosts are detected. The trained ensemble is additionally deployed as a static web page that computes path-dependent TreeSHAP in the browser; agreement with the Python reference is verified over 28,917 attributions.

1 Motivation

A classifier that reports near-perfect accuracy on a held-out split and fails in deployment is a familiar failure, and the usual cause is that the held-out split shares an artifact with the training data. Phishing-URL detection is unusually exposed to this: benign and malicious URLs are almost always harvested from *different* sources — a popularity ranking on one side, an abuse feed on the other — and any systematic difference between those two collection pipelines is available to the model as a shortcut.

This report treats that possibility as the primary object of study rather than as a caveat. The question is not "how accurate can a model be on PhiUSIIL" but "what is the reported accuracy actually measuring".

2 Data

PhiUSIIL [1] contains 235 795 URLs (134 850 legitimate, 100 945 phishing) with 54 precomputed features. Note that the shipped convention is `label = 1` for *legitimate*; this work inverts it so that $y = 1$ denotes phishing.

For out-of-distribution evaluation three further sources were captured on 14 August 2026: **Tranco** [2] top one million domains as a benign proxy; the **PhishTank** verified dump, whose `submission_time` column permits a genuine temporal split; and the **OpenPhish** community feed as a small, fully independent probe of URLs live on the day. ISCX-URL2016 was considered and rejected: it is gated behind a manual registration form and cannot be fetched reproducibly.

3 Two label leaks

3.1 Leak 1: a feature that encodes the label

`URLSimilarityIndex` takes the value `100.000` for *all* 134 850 legitimate rows and for 786 of the 100 945 phishing rows. The rule

$$\texttt{URLSimilarityIndex} \geq 99.9 \;\Rightarrow\; \text{legitimate}$$

achieves 0.9967 accuracy with perfect specificity, on its own, with no model (Figure 1).

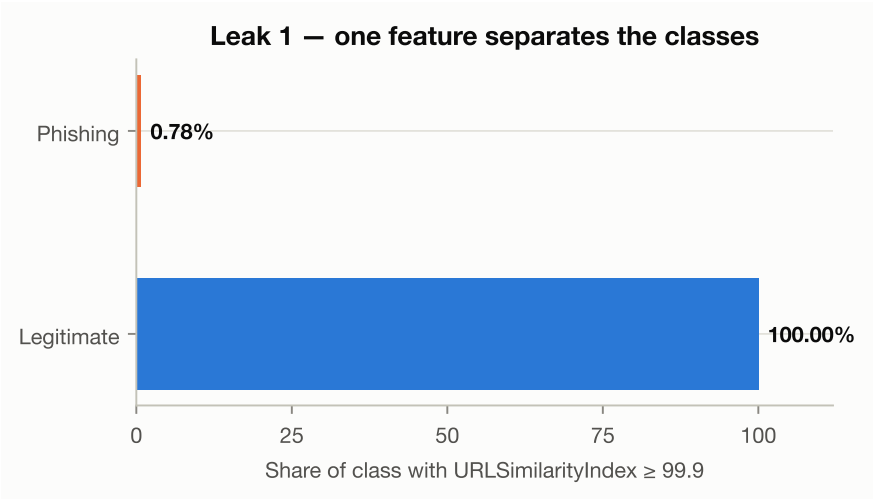


Figure 1: One feature separates the classes almost perfectly. Any model given this column is reporting the column's behaviour, not its own.

3.2 Leak 2: the classes were collected differently

The second leak is structural and more damaging, because it is not confined to a column that can be dropped. Table 1 profiles the two classes.

The legitimate set was normalised to `https://www.<domain>` when it was assembled; the phishing set was written out verbatim from feeds. Consequently *has a path* $\Rightarrow$ *phishing* is 0.6935 accurate and, critically, has a false-positive rate of exactly zero (Figure 2). A model with access to the raw URL string can reach very high accuracy by learning which of two collection pipelines produced a row.

3.3 What the leaks are worth

Table 2 trains LightGBM on progressively cleaner feature sets, using the random 80/20 split that the literature uses.

Trait	Legitimate	Phishing
Scheme is HTTPS	100.00 %	48.74 %
Host starts with `www.`	100.00 %	41.36 %
Has a path	0.00 %	28.42 %
Has a query string	0.00 %	6.08 %
Contains `@`	0.00 %	0.01 %
Mean URL length	27.2	46.2
Rows	134,850	100,945

Table 1: Structural profile by class. Not one of the 134 850 legitimate URLs has a path, a query string or an `@`; every one uses HTTPS and a `www.` host.

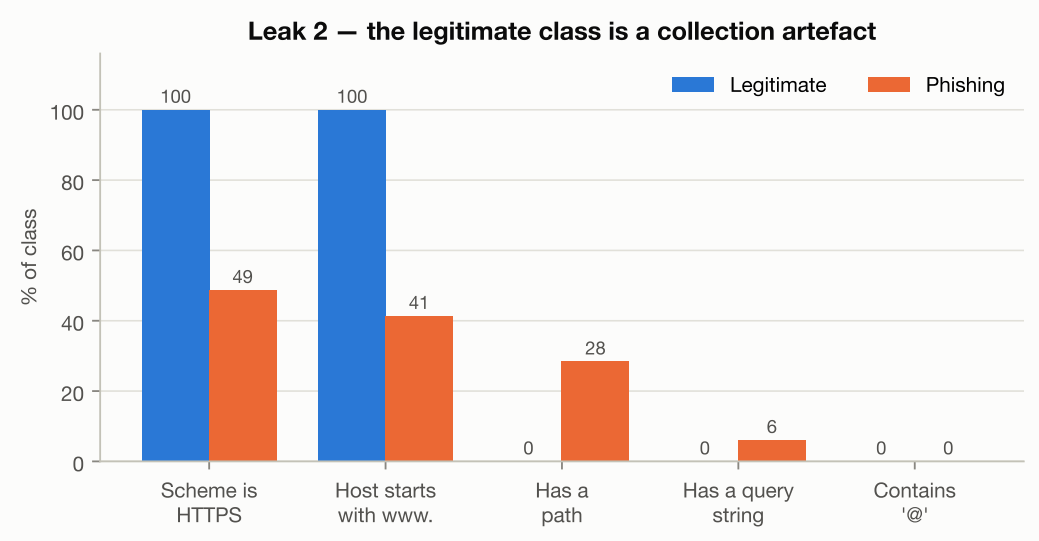


Figure 2: Leak 2. The legitimate class is uniform on four independent traits, which is a property of how it was gathered rather than of legitimate websites.

4 Method

4.1 Canonicalisation

Every URL is reduced to a canonical host name before anything else happens: lowercased, with the scheme, userinfo, port, path, query, fragment, trailing dot and leading `www.` removed. This is what neutralises leak 2, and it simultaneously removes a trap in the out-of-distribution evaluation, where Tranco supplies bare domains and the phishing feeds supply deep URLs — a full-URL comparison there would reproduce the same "has a path" shortcut in a new setting.

The constraint is enforced mechanically rather than by discipline. A guard test mutates the scheme, path, query, port and `www.` prefix of each URL in a corpus and asserts the feature vector is bit-identical; a negative control plants such a leak and confirms the guard detects it.

4.2 Features

51 features are computed from the host name alone, in four groups: *shape* (host and label lengths, subdomain depth), *composition* (Shannon entropy, digit and hyphen ratios, longest digit and consonant runs), *structure* (IP literal, punycode, multi-level suffix, provider-hosted), and *lexical* (login-related keywords, brand tokens, and `brand_in_subdomain_only`, which fires

Feature set	Accuracy
All 50 precomputed features	1.0000
Minus `URLSimilarityIndex`	1.0000
Minus page-content columns (21 features)	0.9973
Hand-rolled lexical features on the raw URL	0.9951

Table 2: Accuracy under a random split. The last row is the important one: discarding every precomputed column and engineering lexical features from the raw URL — the correct instinct on discovering leak 1 — still yields 0.9951, and still measures the collection artifact.

on the `paypal.com.evil.tk` shape).

The top-level domain is one-hot encoded over the 25 most frequent suffixes rather than target-encoded: a TLD phishing prior fitted on the data would reintroduce the label through the back door. The brand vocabulary is frozen from the Tranco top 1000, which ranks by popularity and is therefore label-independent by construction.

4.3 Splitting

Registrable domains are resolved against a frozen Public Suffix List snapshot and used as groups in a `GroupShuffleSplit`, so no eTLD+1 appears on both sides of the split. 219,036 unique hosts across 175,451 registrable domains remain after deduplication.

Only the ICANN section of the list is used for grouping. Under the private section `evil.vercel.app` and `nice.vercel.app` would be distinct groups, letting the model be rewarded at test time for memorising a hosting provider seen in training; grouping under ICANN forces all of `vercel.app` to one side. Provider hosting is exposed as a feature instead, which is where that signal can inform without inflating.

4.4 Evaluation protocol

Two regimes are reported. The *internal hold-out* is the grouped split above. The *out-of-distribution and temporal* set pairs Tranco hosts with PhishTank hosts submitted after 2024-03-04, the date of the PhiUSIIL archive. Three contaminations are removed and counted (Table 3), each of which would otherwise flatter the result — most importantly the 42 005 Tranco hosts that already appear in training, which would make 42 % of a naive benign sample a memory test.

Hosts appearing on both a benign and a phishing list are excluded rather than arbitrated. They are compromised legitimate sites hosting phishing content, a real phenomenon whose label is genuinely ambiguous at the host level.

The primary metric is **recall at a fixed false-positive rate**. A false positive blocks a legitimate site, which is the operationally expensive error, and accuracy on a near-balanced set says nothing about behaviour at a usable operating point.

5 Results

Table 4 reports ROC-AUC 0.9372 and 70.5 % recall at 1 % false positives out of distribution, against 72.6 % internally. On the OpenPhish feed — phishing URLs that were live on the capture date and appear in no training data — 58.5 % of hosts are detected at the same threshold.

	Hosts
Tranco hosts considered	1,000,000
PhishTank hosts (all)	37,244
PhishTank hosts after the cutoff	31,726
Removed: benign already seen in training	42,005
Removed: phishing already seen in training	121
Removed: host on both a benign and a phishing list	267
Final benign	100,000
Final phishing	31,396
OpenPhish probe hosts	260

Table 3: Composition of the out-of-distribution set, including every exclusion.

	Internal hold-out	OOD + temporal
Hosts evaluated	50,332	131,396
Of which phishing	23,424	31,396
ROC-AUC	0.9187	0.9372
PR-AUC	0.9345	0.9078
Recall @ FPR 1 %	72.59 %	70.55 %
Recall @ FPR 0.1 %	63.46 %	50.78 %
Precision at operating point	98.44 %	95.68 %
F_1 at operating point	0.8356	0.8122
False positives	269 / 26,908	999 / 100,000

Table 4: Performance in both regimes. The operating point is the threshold achieving a 1 % false-positive rate.

That out-of-distribution ROC-AUC slightly exceeds the internal figure is worth stating plainly rather than presenting as a success: the grouped internal split is the harder discrimination, because PhiUSIIL's legitimate hosts are long-tail domains, whereas Tranco's benign set is dominated by popular sites whose host names are short, dictionary-like and easy to separate. The two numbers are not directly comparable, and neither is evidence that the model transfers well.

5.1 Choosing the threshold

At the default 0.5 threshold the model produces 13 453 false positives on 100 000 benign hosts. At 0.9768, chosen from the ROC at a 1 % false-positive rate, it produces 999 — a 92.6 % reduction — at a cost of 18 points of recall. For a detector fronting real traffic this is the correct side of the trade, and the service exposes both the threshold and its rationale.

5.2 What the model learned

Figure 5 ranks features by mean absolute SHAP value over 4 000 out-of-distribution hosts. Subdomain depth dominates, followed by digit count, the top-level domain and subdomain length — which is a coherent description of how phishing host names are actually constructed: a recognisable-looking prefix stacked in front of a cheap registrable domain. The twenty-six suffix indicators are summed into a single entry, which is exact because SHAP values are additive.

Notably, the model is *not* leaning on the hand-supplied lexical priors. The keyword list and the brand features rank below the purely structural measurements, which suggests the structural

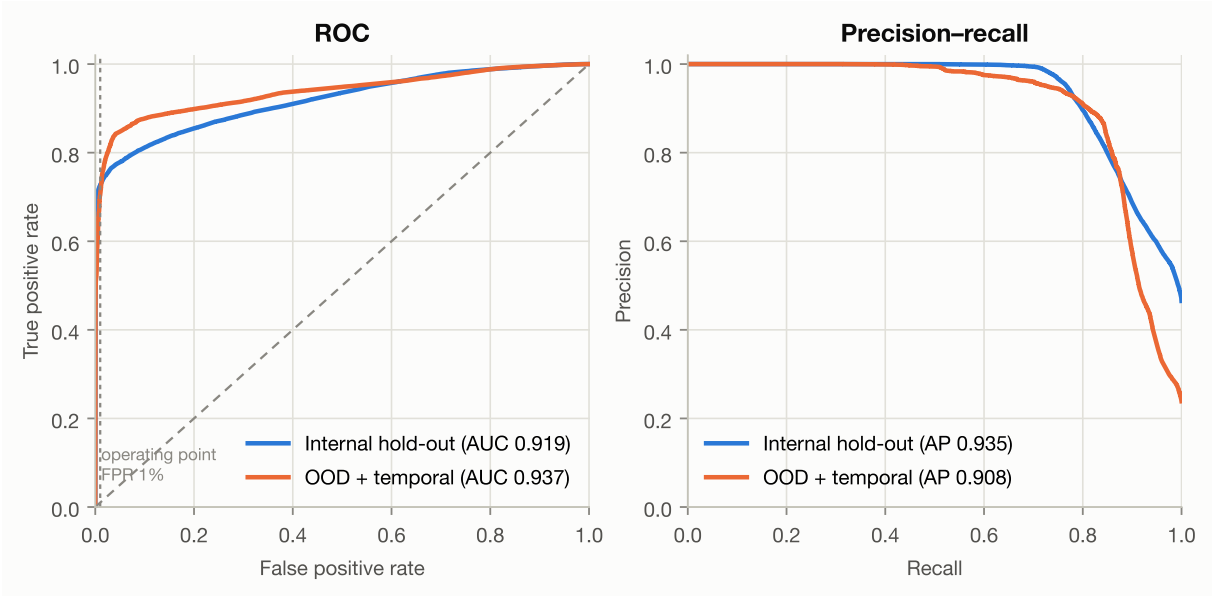


Figure 3: ROC and precision–recall in both regimes. The dashed vertical line marks the 1 % false-positive operating point.

shape of a host name carries more signal than the presence of words a defender thought to enumerate.

6 Client-side scoring and explanation

The public demonstration is a static page with no backend: it loads a 0.86 MB pruned tree ensemble and computes the prediction and its explanation locally. Explanations use path-dependent TreeSHAP [3], reimplemented in JavaScript.

An explanation computed by a reimplementation is only worth showing if it is the same computation. Table 5 reports agreement between the JavaScript engine and the Python reference over a corpus of 567 URLs spanning edge cases and samples from all four data sources.

Compared	Count	Max. abs. difference
Canonical hosts	567	exact
Feature values	28,917	0
Raw scores	567	0
SHAP attributions	28,917	8.9×10^{-16}
SHAP additivity in JS	567	1.9×10^{-13}

Table 5: Python versus JavaScript. Feature values and raw scores agree exactly; SHAP attributions agree to machine precision. For reference, `shap`'s own additivity residual on this stack measures 5×10^{-16}.

A hash of the feature specification travels inside the model artifact, and the page refuses to score if its own extractor disagrees — making train/serve skew a visible failure rather than a quietly wrong probability.

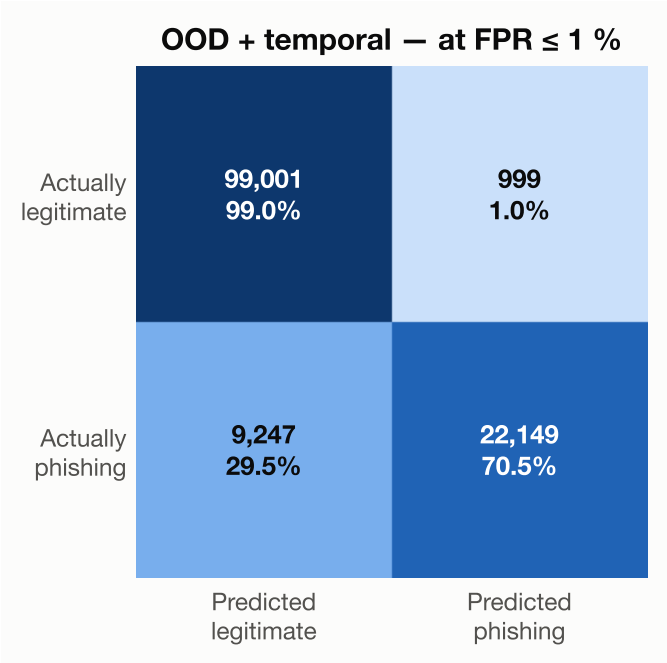


Figure 4: Confusion matrix out of distribution at the 1 % false-positive operating point.

7 Threat-model context

Phishing links correspond to MITRE ATT&CK technique **T1566** and sub-technique **T1566.002** (Spearphishing Link) [4]. The feature `brand_in_subdomain_only` directly targets the impersonation pattern in which a brand name appears in the subdomain but not in the registrable domain, as in `appleid.apple.com.secure-login-verify.xyz`, whose registrable domain is `secure-login-verify.xyz`.

Detection logic lives in version control as tested feature definitions rather than as console configuration, which makes it reviewable and diffable in the same way a Sigma rule or a query-based detection would be.

8 Limitations

This is a support classifier with a measured error rate, not an authority.

It reads host names only. It cannot resolve URL shorteners, whose host is uninformative by design; it cannot inspect page content; and it cannot detect phishing hosted on compromised legitimate domains — 267 hosts in the evaluation data are exactly that case, and were excluded from scoring precisely because a host-level label cannot describe them. At the reported operating point it misses roughly 30 % of phishing.

The benign proxy is a popularity ranking, which under-represents the long tail of small legitimate sites; the false-positive rate on such sites is likely higher than the reported 1 %. The phishing feeds are live and rotate, so the numbers here correspond to the 14 August 2026 capture.

9 Conclusion

A reported accuracy of 1.0000 on PhiUSIIL becomes 70.5 % recall at a 1 % false-positive rate once two label leaks are removed and the model is confronted with phishing that post-dates

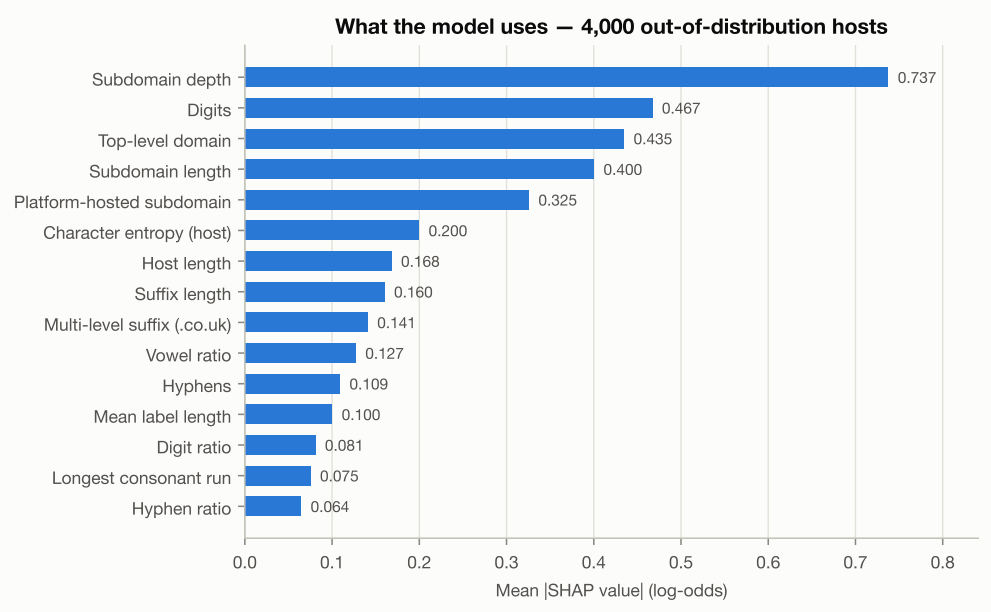


Figure 5: Global feature importance on data the model never saw.

its training data by two years. The distance between those numbers is the contribution of this report. The resulting model is smaller, weaker, and considerably more informative about what lexical phishing detection can actually do.

References

[1] A. Prasad and S. Chandra. *PhiUSIIL: A Diverse Security Profile Empowered Phishing URL Detection Framework*. Computers & Security, 2024. UCI Machine Learning Repository, dataset 967. `https://archive.ics.uci.edu/dataset/967`

[2] V. Le Pochat et al. *Tranco: A Research-Oriented Top Sites Ranking Hardened Against Manipulation*. NDSS, 2019. `https://tranco-list.eu`

[3] S. M. Lundberg, G. G. Erion and S.-I. Lee. *Consistent Individualized Feature Attribution for Tree Ensembles*. arXiv:1802.03888, 2018.

[4] MITRE ATT&CK. *T1566: Phishing*; *T1566.002: Spearphishing Link*. `https://attack.mitre.org/techniques/T1566/`

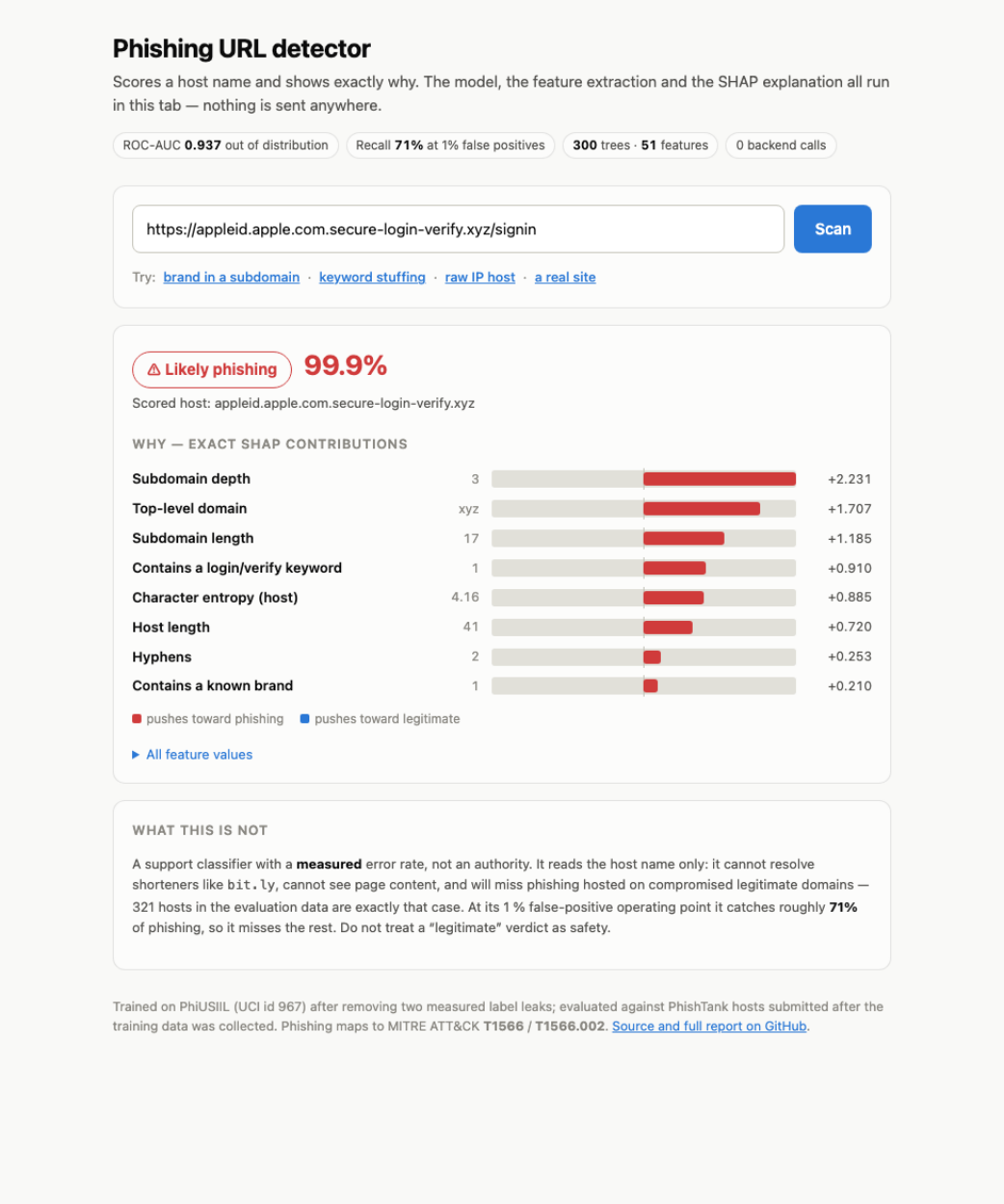


Figure 6: The deployed demonstration explaining a brand-impersonation host. The contributions shown are exact: they sum, with the base value, to the model's log-odds output.